شركة النخبة للخدمات المحاسبية



المستوى 1 من 4

جزئي Partial

الأمن السيبراني يُدار بشكل ارتجالي وردّ فعل، والمخاطر غير معروفة بشكل كافٍ.

أقوى وظيفة: **التعافي** (57.1) · الأضعف: **التحديد** (7)

جزئي 0–39	**مُدرك للمخاطر** 40–59
قابل للتكرار 60–79	**متكيّف** 80–100

ثغرات حرجة تتطلب تدخلاً فورياً

2

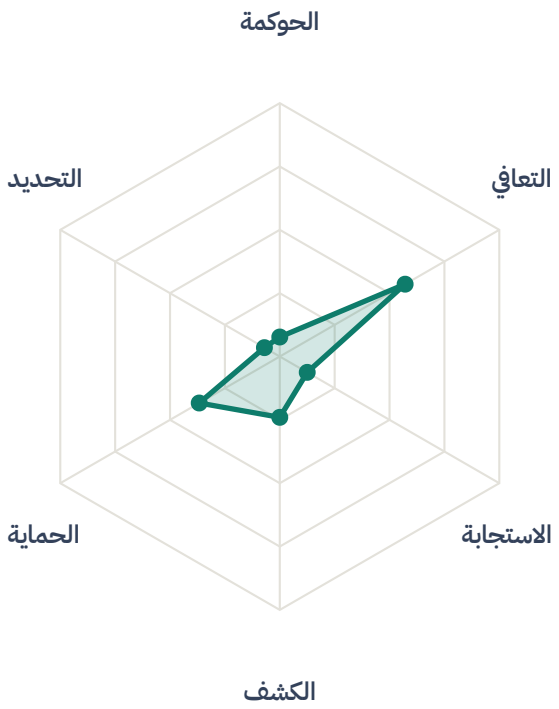
حساباتك مكشوفة لسرقة كلمات المرور

تستخدم خدمات سحابية أو عملاً عن بعد بدون MFA إلزامية. كلمة مرور واحدة مسربة تكفي للدخول إلى البريد والملفات.

خطر برامج الفدية بلا قدرة مضمونة على التعافي

لا توجد نسخة احتياطية معزولة. في هجوم الفدية ستُشفَّر البيانات والنسخ معاً، وقد تضطر للدفع أو خسارة البيانات.

النتيجة حسب وظائف NIST CSF 2.0



الحوكمة GV	7.7	
التحديد ID	7	
الحماية PR	36.7	
الكشف DE	24	
الاستجابة RS	12.5	
التعافي RC	57.1	

الدرجة موزونة: الضوابط التي تمنع الهجمات الأكثر شيوعاً (مثل MFA والنسخ الاحتياطي المختبر) لها وزن أعلى.

أين يمكن أن تصل؟

الدرجة الحالية	بعد المكاسب السريعة
28.6	56.2
بعد خطة الأسبوع الأول	بعد خطة 30 يوماً
36.1	87.6

خطة العمل والتوصيات

25 توصية مرتبة حسب الأولوية والأثر

1

اجعل MFA إلزامية لجميع المستخدمين

من لوحة إدارة Microsoft 365 أو Google Workspace فعّل "فرض MFA" لجميع الحسابات. MFA الاختيارية تترك أضعف حساب مكشوفاً.

أولوية حرجة | الحماية · PR.AA-03 | جهد قليل | مجاني | خلال 7 يوماً | مكسب سريع

↑ وزن أعلى لشركتك: وجود عمل عن بعد يرفع خطر سرقة الهوية

3.9+

نقطة متوقعة

2

عيّن مسؤولاً عن الأمن السيبراني أولاً

حدد مالكاً واضحاً للمخاطر السيبرانية، حتى لو كان المدير أو مسؤول IT بدوام جزئي. اكتب اسمه ومسؤولياته في صفحة واحدة: متابعة التحديثات، مراجعة الصلاحيات، والتواصل عند الحوادث.

أولوية حرجة | الحوكمة · GV.RR-02 | جهد قليل | مجاني | خلال 7 يوماً | مكسب سريع

🔓 تنفيذ هذه الخطوة يفتح 2 ضوابط إضافية تم تخطيها

3.6+

نقطة متوقعة

3

ارسم خريطة مبسطة للبيانات الحساسة

حدد أين تُخزَّن بيانات العملاء والمالية والموظفين (أي جهاز، أي مجلد، أي خدمة)، ثم اجمعها في أماكن محددة ومحمية بدلاً من نسخها على أجهزة متفرقة.

أولوية عالية | التحديد · ID.AM-07 | جهد متوسط | مجاني | خلال 30 يوماً

↑ وزن أعلى لشركتك: القطاع يتعامل مع بيانات حساسة

4.1+

نقطة متوقعة

4

اختبر استعادة النسخ الاحتياطية

قم بجدولة جلسة اختبار استعادة خلال الأسبوعين القادمين. اختر ملفاً مهماً (مثل قاعدة بيانات العملاء) وحاول استعادته على جهاز منفصل.

أولوية عالية · الحماية · PR.DS-11 | جهد قليل | مجاني | خلال 14 يوماً | مكسب سريع

↑ وزن أعلى لشركتك: القطاع يتعامل مع بيانات حساسة

4.1+

نقطة متوقعة

5

نفّذ أول تدريب توعوي ضد التصيد

جلسة واحدة (30 دقيقة) تغطي: التعرف على رسائل التصيد، التحقق من طلبات التحويل المالي هاتفياً، وكيفية الإبلاغ عن رسالة مشبوهة.

أولوية عالية · الحماية · PR.AT-01 | جهد قليل | مجاني | خلال 14 يوماً | مكسب سريع

3.6+

نقطة متوقعة

6

وجّه التنبيهات الأمنية إلى شخص محدد

فعّل تنبيهات الأمان في Microsoft 365/Google Workspace ووجهها إلى المسؤول المعيّن، مع 10 دقائق يومياً لمراجعتها.

أولوية عالية · الكشف · DE.CM-01 | جهد قليل | مجاني | خلال 14 يوماً | مكسب سريع

3.6+

نقطة متوقعة

7

اكتب خطة استجابة من صفحة واحدة

صفحة واحدة تحدد: من يُبلَّغ أولاً، كيف نعزل الجهاز المصاب، أرقام الطوارئ (مزود IT، البنك، المحامي)، ومن يتواصل مع العملاء.

أولوية عالية · الاستجابة · RS.MA-01 | جهد متوسط | مجاني | خلال 30 يوماً

🔒 تنفيذ هذه الخطوة يفتح 1 ضوابط إضافية تم تخطيها

3.6+

نقطة متوقعة

8

أزل صلاحيات المدير من حسابات الموظفين

ابدأ بالأجهزة التي تحتوي بيانات حساسة. احتفظ بحساب مدير منفصل لا يُستخدم للبريد أو التصفح.

أولوية عالية · الحماية · PR.AA-05 | جهد متوسط | مجاني | خلال 30 يوماً

↑ وزن أعلى لشركتك: وجود عمل عن بعد يرفع خطر سرقة الهوية

3.4+

نقطة متوقعة

9

راجع صلاحيات المشاركة السحابية

من لوحة الإدارة، اعرض الملفات المشاركة عبر "أي شخص لديه الرابط" وألغِ غير الضروري منها، وقيّد المشاركة الخارجية افتراضياً.

أولوية عالية · الحماية · PR.AA-05 | جهد قليل | مجاني | خلال 14 يوماً | مكسب سريع

↑ وزن أعلى لشركتك: وجود عمل عن بعد يرفع خطر سرقة الهوية

3.4+

نقطة متوقعة

10

أنشئ جرداً للأجهزة خلال أسبوع

استخدم جدول بيانات بسيط: نوع الجهاز، المستخدم، نظام التشغيل، هل هو مشفر، تاريخ آخر تحديث. حدّثه عند كل تعيين أو مغادرة موظف.

أولوية عالية · التحديد · ID.AM-01 · جهد قليل · مجاني · خلال 14 يوماً · مكسب سريع

+2.7

نقطة متوقعة

11

اعتمد قائمة تحقق لمغادرة الموظفين

اكتب قائمة تحقق ثابتة: تعطيل البريد، تغيير كلمات المرور المشتركة، سحب الأجهزة، إلغاء الوصول السحابي. تُنفَّذ في آخر يوم عمل.

أولوية عالية · الحماية · PR.AA-05 · جهد قليل · مجاني · خلال 14 يوماً · مكسب سريع

↑ وزن أعلى لشركتك: وجود عمل عن بعد يرفع خطر سرقة الهوية

+2.7

نقطة متوقعة

12

تحقق من عزل النسخ الاحتياطية

اسأل مسؤول النسخ: لو شُفّر جهاز الخادم الآن، هل ستُشفَّر النسخة الاحتياطية أيضاً؟ إذا كان الجواب نعم أو لا أعرف، أضف نسخة معزولة.

أولوية متوسطة · الحماية · PR.DS-11 · جهد قليل · مجاني · خلال 14 يوماً

↑ وزن أعلى لشركتك: القطاع يتعامل مع بيانات حساسة

+4.3

نقطة متوقعة

13

أكمل تشفير أجهزة اللابتوب

فعّل BitLocker (Windows Pro) أو FileVault (macOS) على الأجهزة المتبقية واحفظ مفاتيح الاسترداد في مكان آمن.

أولوية متوسطة · الحماية · PR.DS-01 · جهد قليل · مجاني · خلال 30 يوماً

↑ وزن أعلى لشركتك: القطاع يتعامل مع بيانات حساسة

2.4+

نقطة متوقعة

14

فعّل التحديثات التلقائية

فعّل Windows Update والتحديث التلقائي للمتصفحات وبرامج المكتب على جميع الأجهزة، وحدد يوماً شهرياً لمراجعة الأجهزة المتأخرة.

أولوية متوسطة · الحماية · PR.PS-02 · جهد قليل · مجاني · خلال 14 يوماً

2.2+

نقطة متوقعة

15

نفّذ أول فحص أساسي للثغرات

افحص الموقع والعناوين العامة بأدوات مجانية (مثل Qualys SSL Labs لفحص HTTPS)، وراجع المنافذ المفتوحة على الراوتر. أكمل هذا التقييم كل ستة أشهر.

أولوية متوسطة · التحديد · ID.RA-01 · جهد متوسط · تكلفة منخفضة · خلال 45 يوماً

1.8+

نقطة متوقعة

16

افصل شبكة الضيوف

معظم أجهزة الراوتر تدعم "Guest Network" معزولة. فعّلها وغيّر كلمة مرور شبكة العمل الرئيسية.

أولوية متوسطة | الحماية · PR.IR-01 | جهد قليل | مجاني | خلال 14 يوماً

1.8+

نقطة متوقعة

17

وفّر مدير كلمات مرور للفريق

التعليمات وحدها لا تكفي. اعتمد مدير كلمات مرور للفرق (مثل Bitwarden) لتخزين ومشاركة كلمات المرور بأمان.

أولوية متوسطة | الحماية · PR.AA-01 | جهد قليل | تكلفة منخفضة | خلال 30 يوماً

↑ وزن أعلى لشركتك: وجود عمل عن بعد يرفع خطر سرقة الهوية

1.7+

نقطة متوقعة

18

فعّل التحديث التلقائي للموقع

فعّل التحديث التلقائي للإضافات، واحذف الإضافات غير المستخدمة، وخذ نسخة احتياطية من الموقع قبل كل تحديث رئيسي.

أولوية متوسطة | الحماية · PR.PS-02 | جهد قليل | مجاني | خلال 14 يوماً

1.6+

نقطة متوقعة

19

جهّز قالب رسالة للعملاء

جهّز مسبقاً قالب رسالة مختصرة: ماذا حدث، ما البيانات المتأثرة، ماذا فعلنا، وماذا يجب على العميل فعله. حدد من يوافق على إرسالها.

أولوية منخفضة | التعافي · RC.CO-03 | جهد قليل | مجاني | خلال 30 يوماً

+1.8

نقطة متوقعة

20

وسّع حفظ السجلات لكل الأنظمة الحرجة

تأكد من تفعيل سجلات التدقيق (Audit Logs) في البريد والخدمات السحابية والجدار الناري، وحدد مدة احتفاظ 90 يوماً على الأقل.

أولوية منخفضة | الكشف · DE.CM-09 | جهد متوسط | مجاني | خلال 60 يوماً

+1.6

نقطة متوقعة

21

أنشئ قناة إبلاغ رسمية

خصص بريداً (مثل security@) أو زر "إبلاغ عن تصيد" في البريد، وأعلنه لجميع الموظفين.

أولوية منخفضة | الكشف · DE.AE-02 | جهد قليل | مجاني | خلال 14 يوماً

+1.6

نقطة متوقعة

22

أكمل قائمة البرامج والخدمات

راجع كشوف الحساب البنكي والبطاقات لاكتشاف الاشتراكات السحابية غير المسجلة، وأضفها مع اسم مالك كل خدمة.

أولوية منخفضة | التحديد · ID.AM-02 | جهد قليل | مجاني | خلال 30 يوماً

+1.1

نقطة متوقعة

23

وثّق متطلبات الأمن مع الموردين

أضف بنوداً بسيطة للعقود: إشعار فوري عند الاختراق، حماية البيانات، وحذف البيانات عند انتهاء العقد.

أولوية منخفضة · الحوكمة · GV.SC-07 · جهد متوسط · مجاني · خلال 60 يوماً

0.9+

نقطة متوقعة

24

أكمل قائمة اتصالات الطوارئ

أضف الجهات الناقصة واحفظ نسخة مطبوعة خارج الأنظمة (لأن الأنظمة قد تكون معطلة أثناء الحادث).

أولوية منخفضة · الاستجابة · RS.CO-02 · جهد قليل · مجاني · خلال 14 يوماً

0.9+

نقطة متوقعة

25

وثّق أهداف وقت الاستعادة

اكتب لكل نظام حرج: أقصى وقت توقف مقبول (RTO) وأقصى فقدان بيانات مقبول (RPO)، وقارنه بقدرات النسخ الاحتياطي الحالية.

أولوية منخفضة · التعافي · RC.RP-03 · جهد قليل · مجاني · خلال 30 يوماً

0.9+

نقطة متوقعة

ملحق: الإجابات

◄ عرض جميع الأسئلة والإجابات (33)